

Information Security and Acceptable Use Policy

Document ID: IT-POL-001 Version: 5.1

Effective Date: 1 February 2026 Owner: Information Security

Classification: Internal Supersedes: IT-POL-001 v5.0

1. Data classification

Class | Definition | Handling

Public | Approved for release outside the company | No restriction

Internal | Ordinary business information | Company systems only, not shared externally without approval

Confidential | Customer data, contracts, employee records | Encrypted at rest and in transit, need-to-know access

Restricted | Credentials, security keys, unreleased financial results | Named individuals only, access logged monthly

2. Access control

Access is granted on the principle of least privilege and reviewed quarterly. Multi-factor authentication is mandatory for all systems holding Confidential or Restricted data. Shared accounts are prohibited; where a system cannot support individual accounts, an exception must be recorded under section 5. Access is revoked on the last working day for leavers, and immediately where employment ends without notice.

3. Passwords and credentials

Minimum 14 characters, or 12 characters where multi-factor authentication is enforced.

Passwords are stored only in the approved password manager; storing credentials in documents, spreadsheets or chat messages is prohibited. API keys and tokens are rotated at least every 180 days, and immediately if exposure is suspected.

4. Acceptable use

Company systems are provided for business use. Limited personal use is permitted where it does not interfere with work, consume significant resources, or breach this policy.

Installing unapproved software, disabling security controls, and connecting personal storage devices to company equipment are prohibited.

5. Exceptions

Where a control in this policy cannot be met, a written exception request is submitted to the Information Security Officer setting out the business reason, the compensating controls in place, and a review date. Exceptions are granted for a maximum of six months and are recorded in the exception register. An exception that has not been formally granted does not exist, and proceeding without one is treated as a policy breach.

6. Incident reporting

Report a suspected incident to the Information Security Officer immediately, and in any event within one hour of becoming aware of it. Do not attempt to investigate or remediate on your own. Preserve evidence: do not delete messages, files or logs. The Information Security Officer determines whether the incident is notifiable and to whom. Reporting an incident in

good faith never attracts disciplinary action, including where the reporter caused it. Failing to report one does.

7. Annex B, third-party security questionnaire

Suppliers that will process personal data on the company's behalf complete the Annex B questionnaire during vendor onboarding, PROC-PRO-002 stage 3. It covers data location, sub-processors, encryption, breach notification timelines, and deletion on termination. A supplier that cannot commit to breach notification within 72 hours is escalated to the Information Security Officer before approval.